

ESP32-S3 Production Firmware

Corrected MQTT Sequence following EMQX Broker Best Practices

ETERNITY / ONEOPS Platform — companion to the *Unified Technical Specification v1.0*

Revised 2026-06-08

1 Scope and what was corrected

The specification’s end-to-end sequence (§5.6/§5.7) begins at **publish reading** and treats the broker as a dumb pipe. That hides the parts of the firmware contract that actually decide field reliability: *how the device authenticates, how presence is tracked, how sessions and commands survive a flaky link, and how firmware is delivered safely*. This document redraws the lifecycle of a single production device against **EMQX** broker semantics (MQTT 5.0) and marks every correction.

Area	Original spec	Corrected — EMQX best practice
Transport & auth	shared / implicit; “returns mTLS cert” but no handshake shown	one-time factory <i>bootstrap</i> token over server-auth TLS, immediately rotated to per-device X.509 client certificate ; steady state is mutual TLS 1.3 verified by EMQX.
Client identity	“initial <code>device_id</code> ”	stable, unique <code>mqtt_client_id</code> bound to the certificate CN; duplicate-ID takeover rejected.
Authorization	not stated	EMQX ACL : a device may only publish/subscribe under <code>devices/{id}/#</code> and <code>sensors/{sid}/raw</code> ; cross-device spoofing denied.
Session	not stated	MQTT 5.0 <code>clean_start=0</code> + Session-Expiry , so QoS 1 commands queued during a brief drop are re-delivered on reconnect.
Presence (LWT)	status is “LWT topic”, retain unspecified	Will published QoS 1, retain=1 ; matching birth message on (re)connect clears it, so late subscribers always read correct state.
Config delivery	plain publish	<code>devices/{id}/config</code> published retain=1, QoS 1 ⇒ device gets current config the instant it subscribes.
Heartbeat	QoS 0, retain=0 ✓	kept QoS 0; <code>keepalive=60 s</code> , EMQX dead-peer detection at $1.5\times$ keepalive.
Sensor reading	QoS 1, retain=0 ✓	kept QoS 1 (PUBACK); ingest consumes via an EMQX shared subscription (<code>\$share/ingest/...</code>) for horizontal scale + back-pressure.
OTA	“upgrade to 1.4.2 from <code>artefact_uri</code> ”	signed artefact (SHA-256 + secure-boot), A/B partition, out-of-band HTTPS fetch, <code>ota/progress</code> telemetry, automatic rollback , audit row in <code>device_firmware_history</code> .
Abuse control	none	EMQX flapping detection + per-client message/bandwidth rate limits.

Legend. $\longrightarrow$ solid = MQTT control packet / synchronous call $\dashrightarrow$ dashed = broker delivery / asynchronous event $\cdots\rightarrow$ dotted = return / acknowledgement.

2 Phase A — Zero-touch provisioning & secure session bring-up

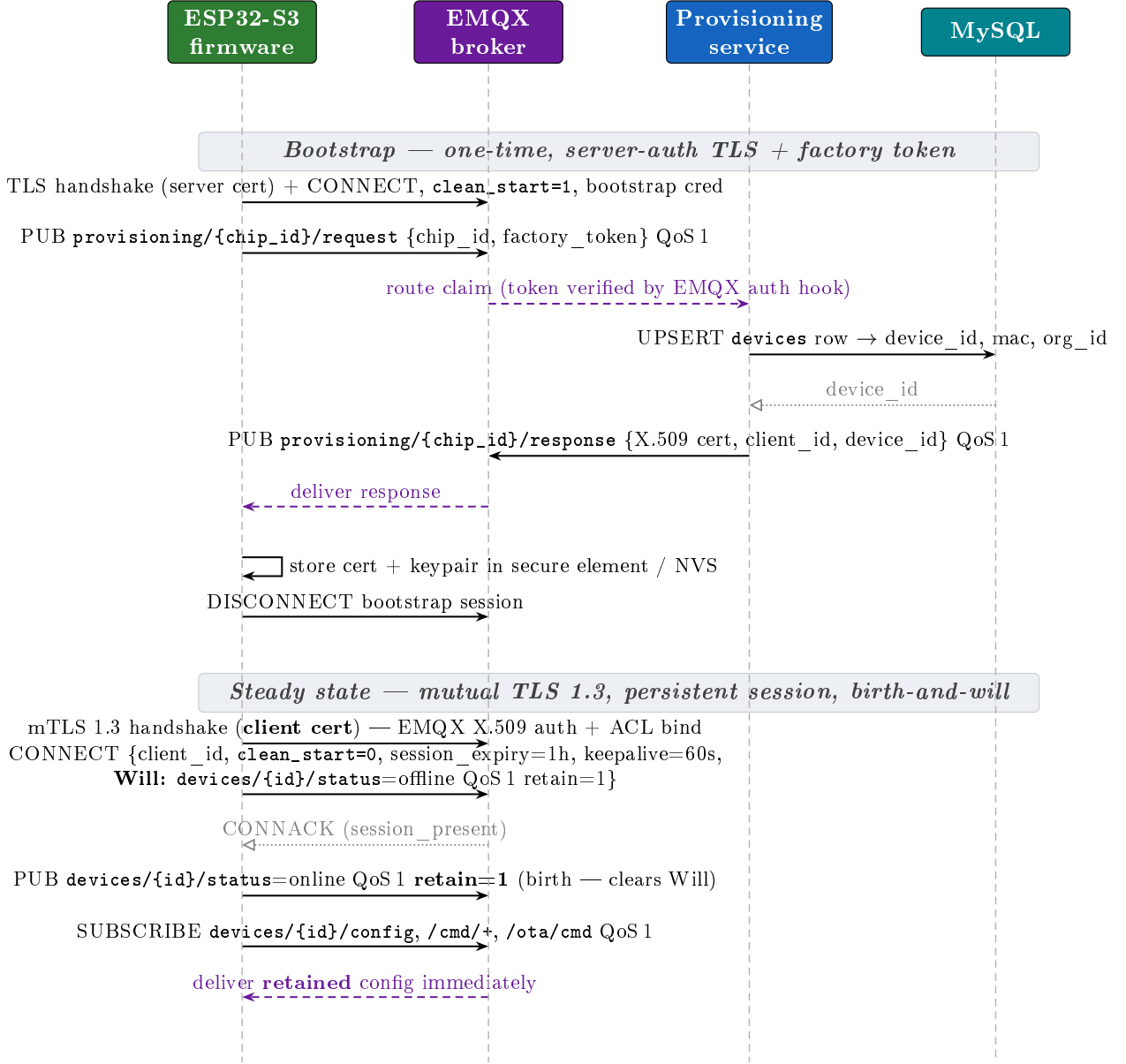


Figure 1: Phase A — provisioning rotates a factory token into a per-device certificate, then the production session is established with mutual TLS, a persistent MQTT 5.0 session, and a retained will/birth pair so presence is never stale.

3 Phase B — Steady-state telemetry (corrected ingestion)

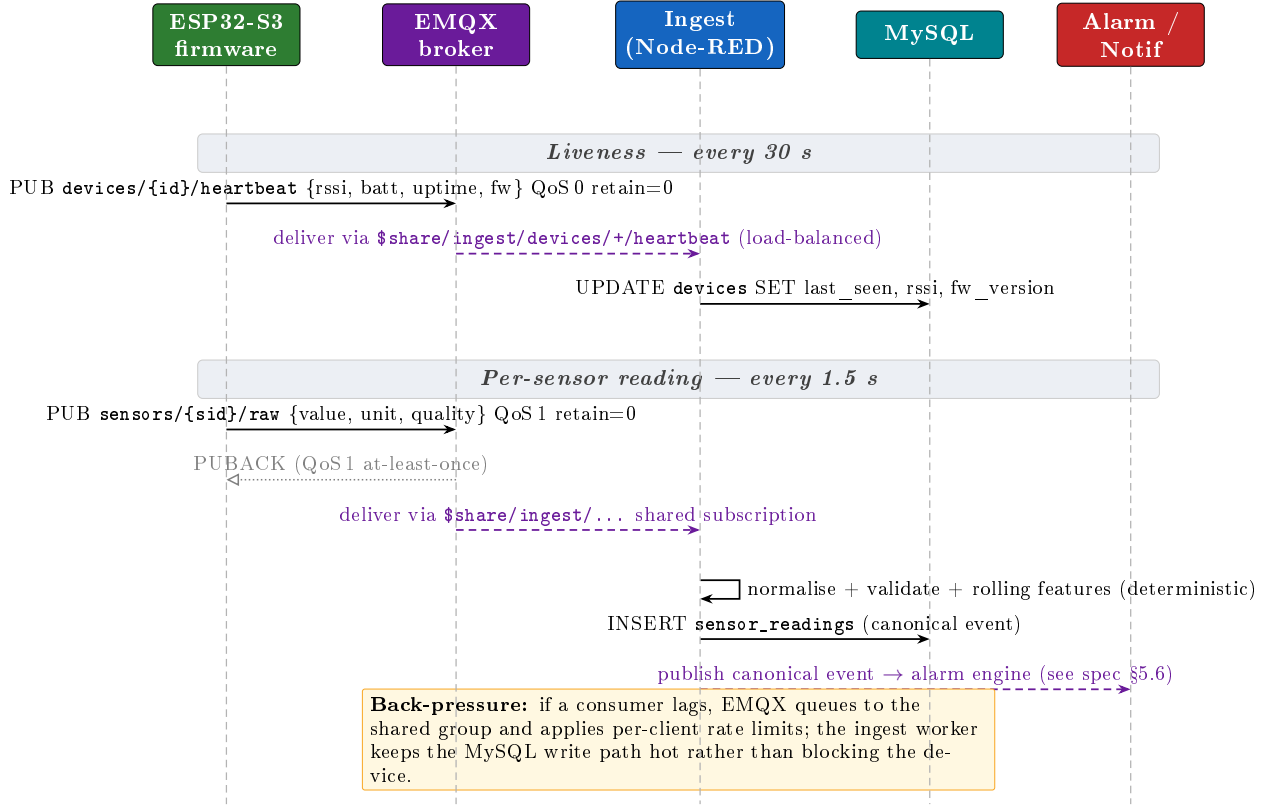


Figure 2: Phase B — heartbeats stay QoS 0; sensor readings stay QoS 1 with PUBACK. The single correction that matters for scale is consuming through an EMQX *shared subscription*, which load-balances across ingest replicas and gives the broker a place to absorb back-pressure.

4 Phase C — Signed OTA update with A/B rollback

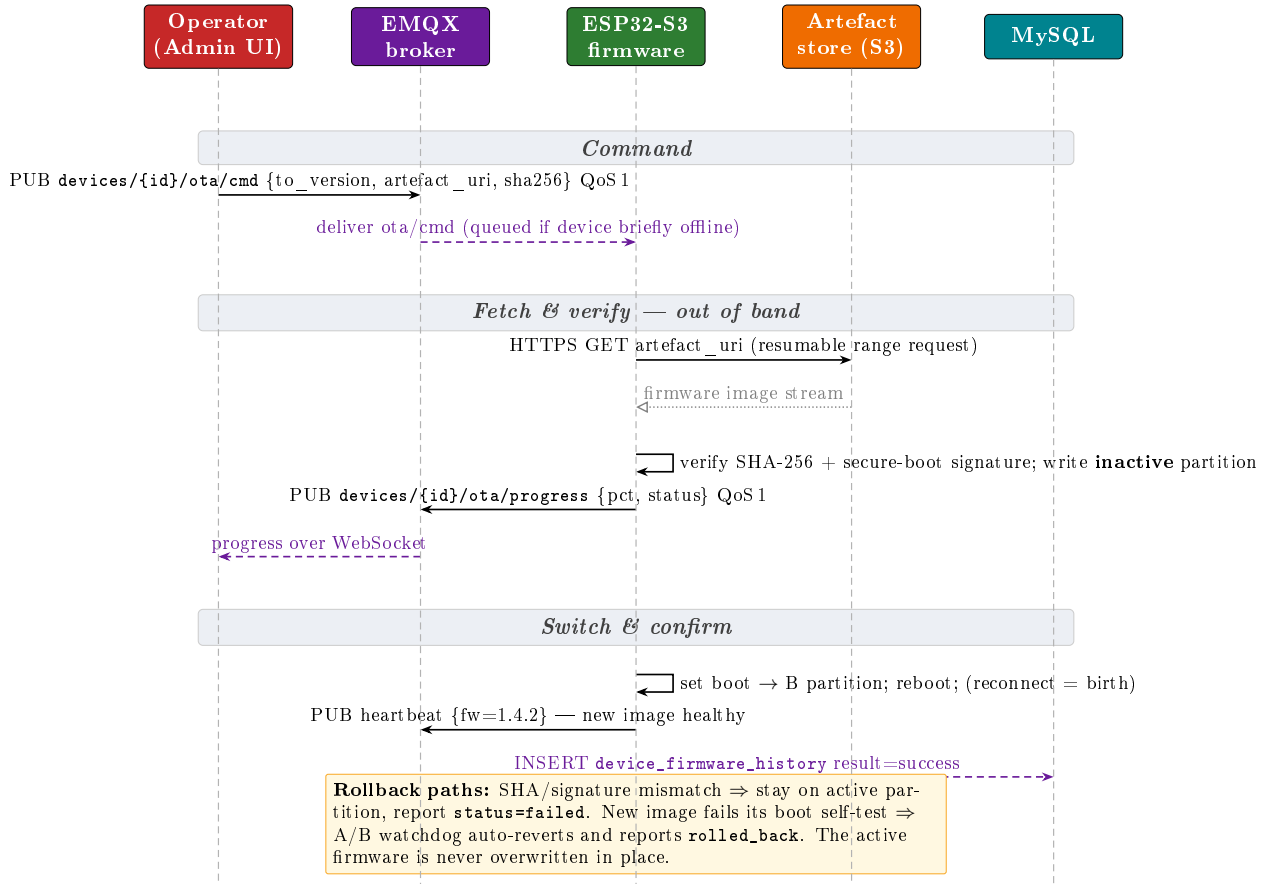


Figure 3: Phase C — OTA is delivered as a signed artefact fetched out of band over HTTPS, flashed to the inactive A/B slot, and only promoted after verification; the firmware version reported in the next heartbeat closes the audit loop.

5 Phase D — Ungraceful disconnect (Last Will & Testament)

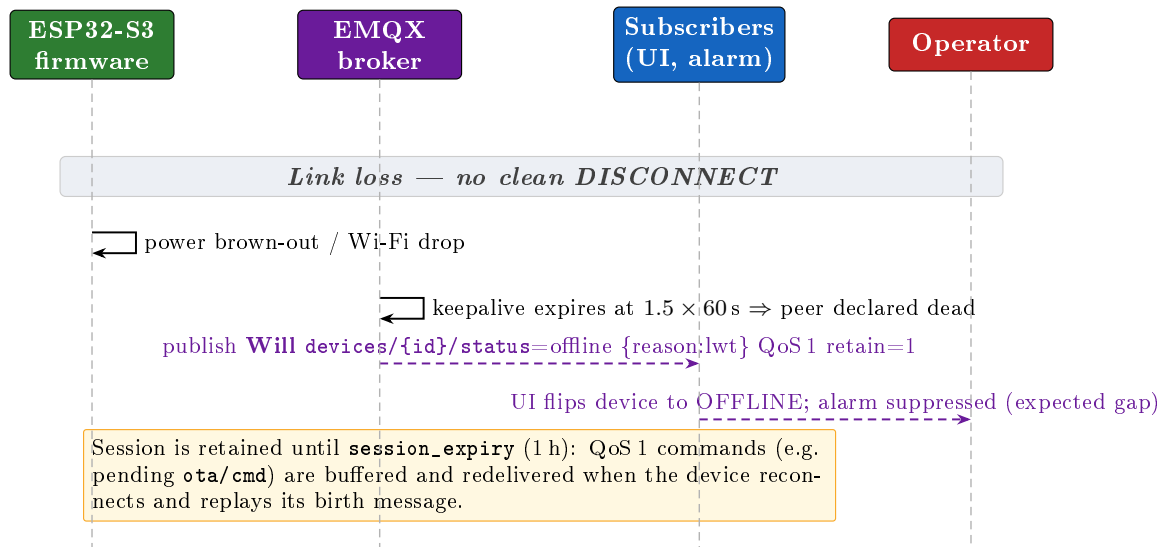


Figure 4: Phase D — because the Will is registered at CONNECT with retain=1, presence stays correct without any device cooperation; the retained session keeps queued commands alive across the outage.

6 Per-product telemetry — one envelope, three payload profiles

The phases above are deliberately product-agnostic because every device speaks the *same* firmware contract. Temperature is transmitted by all three product lines, but it is only *one channel* inside a product-specific set. A device emits **one sensors/{sid}/raw publish per channel per cycle**; the broker and ingest path are identical, and the meaning of each `sensor_id` is resolved by the polymorphic *CTI* model (`sensors.host_fk` $\in$ {t,c,b} $\rightarrow$ exactly one of the three `*_sensor_specs` tables). What actually differs per product is the *channel set*, units, and cadence.

Product line (host)	Cadence		Channels emitted as sensors/{sid}/raw
Refrigeration Data Logger (carbonbox, host=c)	temp 30–60 s;	door on-change	temp_c (°C); door_state (bool 0/1 — <i>event</i> , not a scalar measurement). Cold-chain min/max only.
BloodBOX (host=b)	temp/RH 10–30 s;GPS 1–5 s in transit;impact event-driven		temp_c, rh_pct (humidity), batt_pct, impact_g (shock), gps (lat/lng — <i>compound</i>), baro_alt_m (floor/altitude). Medical transit; richest payload.
Transformer Monitoring (eternity, host=t)	thermal 30–60 s;	DGA minutes–hours	oil_temp_c, ambient_temp_c, dga_h2_ppm (dissolved hydrogen), moisture_pct, oil_level_pct, load_pct. Multi-channel DGA + thermal.

The deltas the generic envelope must absorb: `door_state` and `impact_g` are boolean/event channels mapped as `value` $\in$ {0,1} / `unit=event`; `gps` is a compound channel (sent as two readings `lat`, `lng` or one structured value); cadences span three orders of magnitude (GPS seconds vs. DGA hours). None of this changes the topic or QoS — only the channel set and the spec table the ingest worker joins to.

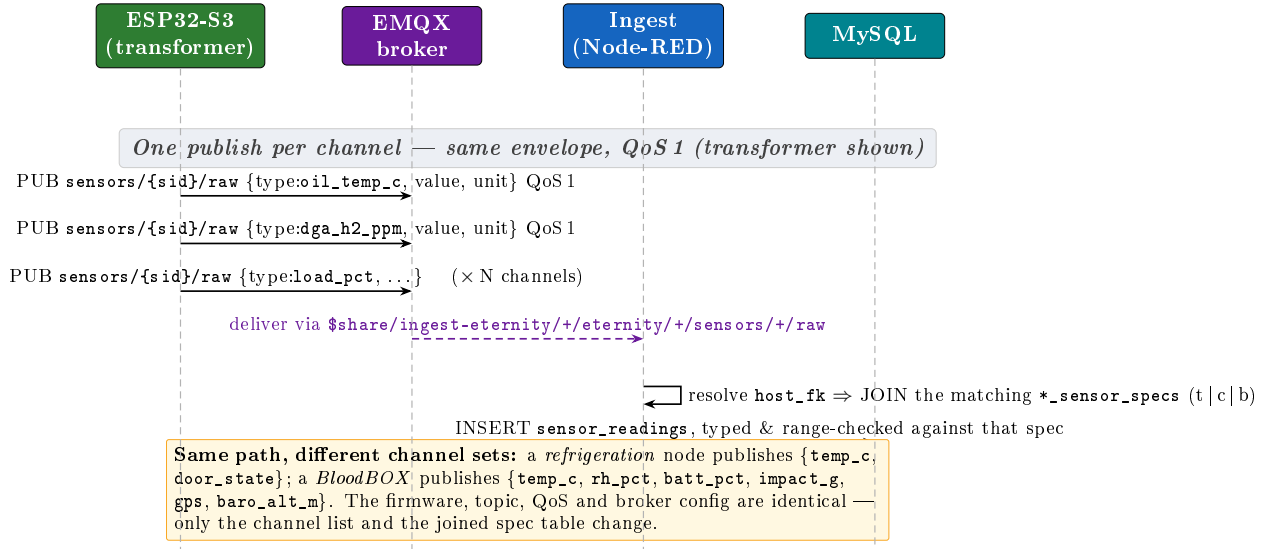


Figure 5: Phase B (per-product) — each device fans out one reading per channel over the single `sensors/{sid}/raw` envelope; the ingest worker resolves the polymorphic host FK and joins the correct per-type spec table, so a 6-channel transformer and a 2-channel fridge share one pipeline.

7 Per-product topic namespace (corrected)

Phases A–D used the device-rooted *tail* of each topic (`devices/{id}/...`, `sensors/{sid}/...`) for legibility. The complete, ACL-enforceable form prefixes **every** production topic with `{tenant}/{product}/{device_id}`, where `product` $\in$ `{eternity, carbonbox, bloodbox}`. The prefix is not cosmetic — it is what lets one broker host three products without cross-talk.

Why product belongs in the topic (EMQX best practice).

- **Isolation & ACL:** the cert CN is `{tenant}.{product}.{device}`; EMQX templates one allow rule `#{cn_tenant}/#{cn_product}/#{cn_device}/#` and denies everything else. A device physically cannot publish into another product.
- **Per-product ingest pools:** each product runs its own shared-subscription group (`$share/ingest-eternity/...`), because the processing differs — DGA gas-trend models, fridge door-debounce, BloodBOX GPS + excursion timers.
- **Per-product schema, retention, alarm thresholds (§8)** are keyed off the `product` segment with no payload sniffing.
- **Fleet analytics by wildcard:** `+/eternity/#` = every transformer across all tenants (superadmin); `acme/#` = one tenant, all products.

Topic	Dir	QoS	Ret	Notes
<i>Bootstrap listener — pre-identity, flat namespace</i>				
<code>provisioning/{chip_id}/request</code>	D→B	1	0	claim with factory token
<code>provisioning/{chip_id}/response</code>	B→D	1	0	returns X.509 cert + client_id
<i>Production listener — prefix P = {tenant}/{product}/{device_id}</i>				
<code>P/status</code>	D→B	1	1	Will <i>and</i> birth
<code>P/heartbeat</code>	D→B	0	0	30s; liveness & fw_version
<code>P/sensors/{sid}/raw</code>	D→B	1	0	per-channel reading; ingest via \$share
<code>P/alarm/{sid}</code>	B→★	1	1	alarm-engine state, retained (§9)
<code>P/config</code>	B→D	1	1	retained; per-product thresholds (§8)
<code>P/cmd/{op}</code>	B→D	1	0	reboot / calibrate / set-threshold
<code>P/ota/cmd</code>	B→D	1	0	signed artefact descriptor
<code>P/ota/progress</code>	D→B	1	0	percent + status

★ = subscribers: UI (WebSocket bridge), notification service, and optionally the device itself for actuation.

Per-product shared subscriptions & ACL roles.

Role	Authorised topic filter
device (each)	<code>pub+sub {tenant}/{product}/{device}/#</code> only
ingest-eternity	<code>sub \$share/ingest-eternity+/eternity+/sensors+/raw</code>
ingest-carbonbox	<code>sub \$share/ingest-carbonbox+/carbonbox+/sensors+/raw</code>
ingest-bloodbox	<code>sub \$share/ingest-bloodbox+/bloodbox+/sensors+/raw</code>
alarm-engine	<code>pub +/+/+alarm/+;</code> <code>sub +/+/+sensors+/raw</code>
ui / notif	<code>sub {tenant}/#</code> (tenant-scoped, read-only)

8 Per-product alarm thresholds

Thresholds are **not** compiled into firmware. They ship in the retained P/config payload (§7), so the alarm engine and the device's edge fast-path share one source of truth and an operator can retune without an OTA. The values below are taken from the current product logic in `src/lib/`; rows marked (*proposed*) have no hardcoded value yet and are filled with defensible medical/industrial defaults.

Channel	Unit	Warn	Crit	Dir	Guard / debounce
Transformer — eternity (host = t)					
oil_temp_c	°C	80	95	↑	WARN after 2 consecutive readings
ambient_temp_c	°C	40	50	↑	
dga_h2_ppm	ppm	150	300	↑	slow DGA cadence; trend-aware
moisture_ppm	ppm	25	35	↑	
oil_level_pct	%	70	60	↓	inverted (low = bad)
load_pct	%	80	95	↑	
Refrigeration — carbonbox (host = c)					
temp_c	°C	6	8	↑	WARN >6 after 2 readings
door_state	bool	—	open	—	CRITICAL; corrected: debounce >60 s
online	bool	—	offline	—	CRITICAL after 1.5×HB (≈90 s)
BloodBOX — bloodbox (host = b)					
temp_c	°C	6	7	↑	medical: no debounce
excursion	°C	—	> maxTempC (8)	↑	per-transit limit + excursion-time audit
rh_pct	%	80	90	↑	humidity (<i>proposed</i>)
batt_pct	%	40	20	↓	low = bad
impact_g	g	—	3.0	↑	single-sample event ⇒ CRITICAL
lid_state	bool	open	—	—	WARNING on open

Direction: ↑ = high value is bad, ↓ = low value is bad. `door_state/impact_g/lid_state` are event channels (§6).

Retained P/config threshold payloads (one per product).

```
eternity: {"product":"eternity","sample_s":30,"dga_sample_s":3600,
  "thresholds":{
    "oil_temp_c": {"warn":80,"crit":95,"dir":"high","debounce_n":2},
    "ambient_temp_c":{"warn":40,"crit":50,"dir":"high","debounce_n":2},
    "dga_h2_ppm": {"warn":150,"crit":300,"dir":"high"},
    "moisture_ppm": {"warn":25,"crit":35,"dir":"high"},
    "oil_level_pct":{"warn":70,"crit":60,"dir":"low"},
    "load_pct": {"warn":80,"crit":95,"dir":"high"}}}

carbonbox: {"product":"carbonbox","sample_s":30,
  "thresholds":{
    "temp_c": {"warn":6,"crit":8,"dir":"high","debounce_n":2},
    "door_state": {"crit_after_s":60},
    "online": {"crit_after_s":90}}}}

bloodbox: {"product":"bloodbox","sample_s":15,"gps_sample_s":3,
  "thresholds":{
    "temp_c": {"warn":6,"crit":7,"dir":"high"},
    "excursion": {"max_temp_c":8,"audit":true},
    "rh_pct": {"warn":80,"crit":90,"dir":"high"},
    "batt_pct": {"warn":40,"crit":20,"dir":"low"},
    "impact_g": {"crit":3.0,"event":true},
    "lid_state": {"warn_on_open":true}}}}
```

9 Alarm semantics & state machine per product

The alarm engine is the canonical owner of state; the device never decides an alarm row (it may only raise an *edge* hint). State follows the spec §5.5 lifecycle, with these per-product guard differences:

NORMAL → WARNING → CRITICAL → ACKNOWLEDGED → ESCALATED → CLEARED

Product	Guard differences vs. the shared §5.5 lifecycle
eternity	WARNING requires 2 consecutive over-threshold readings; CRITICAL is immediate at $\geq \text{crit. oil_level}$ inverted. One alarm row <i>per channel</i> ; DGA evaluated on a slow cadence with a rising-trend pre-empt.
carbonbox	<code>door_state=open</code> and <code>online=offline</code> bypass the 2-reading debounce $\Rightarrow$ immediate CRITICAL (safety). The corrected design adds a 60s door debounce so routine access does not nuisance-trip.
bloodbox	Temperature is medical $\Rightarrow$ no debounce. The CRITICAL bound is the per-transit <code>maxTempC</code> (mobile, default 8), tracked with an excursion-time audit trail. <code>impact_g</code> is a single-sample event; <code>batt_pct</code> low.

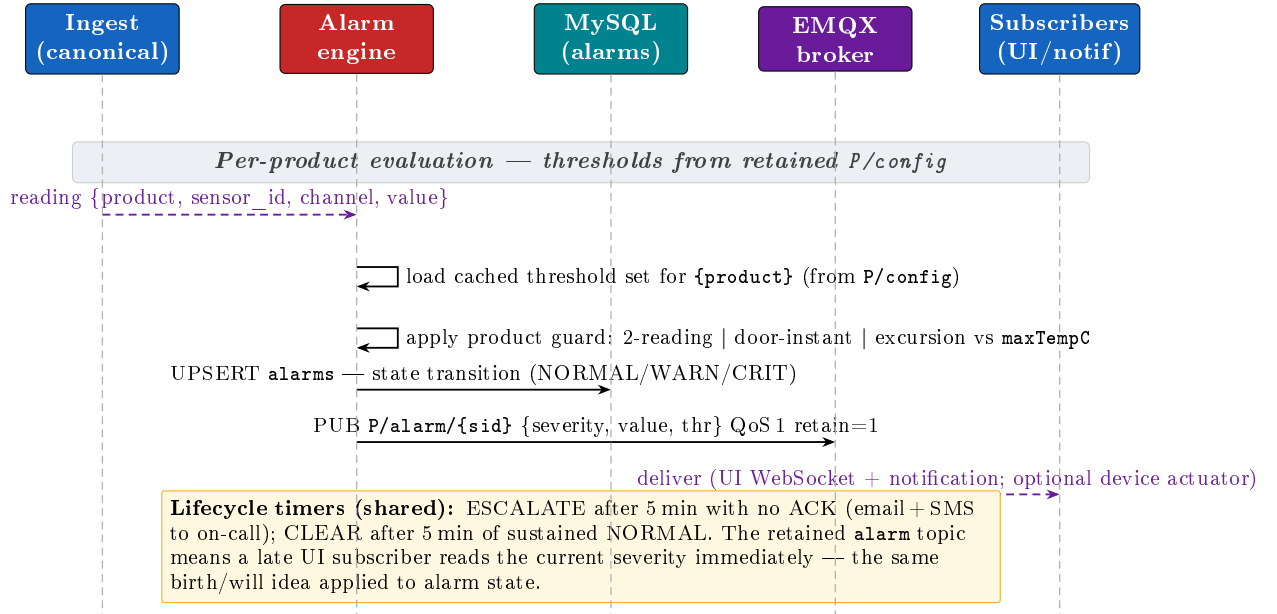


Figure 6: Phase E — one alarm engine, three threshold sets. The reading carries its **product**; the engine loads that product’s thresholds and guard, transitions the **alarms** row per §5.5, and republishes the result on the retained per-device **alarm** topic so presence-of-alarm is never stale.

EMQX configuration checklist.

- Dedicated TLS listeners: a *bootstrap* listener (server-auth, token) and a *production* listener (mutual TLS, `verify=verify_peer, fail_if_no_peer_cert=true`).
- Authentication chain: `X.509 CN {tenant}.{product}.{device} → client_id`; reject mismatched or duplicate client IDs.
- Authorization (ACL) templated from the CN so each device is boxed into `{tenant}/{product}/{device}/#` (§7).
- One shared-subscription group *per product* for ingest; alarm engine and UI on their own scoped roles; never a single static subscriber.
- Flapping detection + per-client rate & bandwidth limits enabled.
- Session expiry sized to the longest tolerable command-delivery gap (here 1 h).